Internet das coisas

Segurança no Desenvolvimento de Software

OWASP - Visão Geral

Prof. Ana Beatriz Morais

AGO/2026

SENAI
PELO FUTURO DO TRABALHO

O que veremos hoje

- **OWASP?**
  - Significado
  - Para que serve
  - Os 10 riscos mais comuns da última versão (2025)
  - De onde vem os dados
  - O que entra e o que sai na lista
  - E quem decide quem entra e quem sai
- **Atividade de fixação**



OWASP (Open Web Application Security Project)

OWASP

- **OWASP** → Open WorldWide Application Security Project
  - Projeto de Segurança de Aplicações Web Abertas.
  - Não é uma ferramenta, nem linguagem de programação.
  - É uma organização/comunidade mundial que trabalha para melhorar a segurança de aplicações e sistemas.
  - É uma referência para ajudar desenvolvedores a entenderem como uma aplicação pode ser atacada e como protegê-la.

OWASP

- **Analogia**: OWASP é como um especialista em segurança de uma casa.
  - Você construiu sua casa;
  - Nessa casa você colocou: janela, fechadura, porta, alarme, câmera, muro, etc;
  - Você se pergunta: “Como sei que minha casa está realmente segura?”;
  - Você chama um especialista em segurança, ele vai analisar e falar:
    - “essa janela está fácil de abrir”
    - “esse muro tem um ponto onde alguém consegue entrar”
    - “a senha do seu alarme está muito fraca e pode ser desativado facilmente”

OWASP

- O **OWASP faz algo parecido**, mas **com aplicações web**.
  - Ele ajuda a identificar:
    - "Onde sua aplicação pode estar vulnerável e como você pode protegê-la?"
  - Eles catalogam os erros que mais causaram vazamentos de dados e invasões reais, e publicam essa lista para que outros desenvolvedores não cometam os mesmos erros.
  - Assim como hospitais têm protocolos escritos por médicos experientes sobre como agir em emergências comuns (parada cardíaca, engasgo etc.), a **OWASP escreve "protocolos" sobre como lidar com as ameaças mais comuns que um sistema pode sofrer**: alguém tentando adivinhar senhas, alguém injetando comandos maliciosos num formulário, alguém interceptando dados que deveriam estar protegidos.

O que isso tem a ver com programação?

- Usuário envia as seguintes informações para o servidor
  - Login: ana@email.com
  - Senha: 123456
- O desenvolvedor (que não pensa na segurança) pensa:
  - “Funcionou. O usuário consegue entrar.”
- O profissional de segurança pergunta?
  - "E se alguém tentar colocar uma informação maliciosa nesse campo?"
- Aí começamos a entrar nos problemas estudados pelo OWASP.



OWASP Top 10

OWASP Top 10

- O **OWASP Top 10** é um documento padrão de conscientização para desenvolvedores e segurança de aplicações web. Ele representa um amplo consenso sobre os riscos de segurança mais críticos para aplicações web.
- As empresas devem adotar este documento e iniciar o processo para garantir que seus aplicativos web minimizem esses riscos.
- Utilizar o OWASP Top 10 é talvez o primeiro passo mais eficaz para mudar a cultura de desenvolvimento de software da sua organização, transformando-a em uma [empresa] que produza código mais seguro.

OWASP Top 10

- Versão mais atual: https://owasp.org/Top10/2025/
- 2025 é a versão atualmente mais recente.
  - A01:2025 - Controle de Acesso Quebrado
  - A02:2025 - Configuração Insegura
  - A03:2025 - Falhas na Cadeia de Suprimentos de Software
  - A04:2025 - Falhas Criptográficas
  - A05:2025 - Injeção
  - A06:2025 - Design Inseguro
  - A07:2025 - Falhas de Autenticação
  - A08:2025 - Falhas de Integridade de Software ou de Dados
  - A09:2025 - Falhas de Registro e Monitoramento de Segurança
  - A10:2025 - Tratamento Incorreto de Condições Excepcionais

OWASP Top 10

- **Principais versões:**
  - OWASP Top 10 - 2003 - 2004 - 2007 - 2010 - 2013 - 2017 - 2021 - 2025
- **Quando se atualiza?**
  - Quando existe uma mudança relevante no cenário de segurança, a OWASP trabalha em uma nova edição.
  - A versão de 2025 é a oitava edição do Top 10.
- **Como decidem o que entra e o que sai no TOP 10?**
  - Existe uma metodologia baseada em dados + experiência da comunidade.
  - Na edição 2025, a OWASP analisou dados de segurança de aplicações e informações relacionadas a vulnerabilidades.
  - Foram analisados dados de mais de 2,8 milhões de aplicações fornecidos por organizações da área de segurança.

OWASP Top 10

- **De onde vêm os dados?**
  - A OWASP recebe contribuições de empresas e profissionais de segurança. Por exemplo:
    - empresas de segurança;
    - consultorias;
    - ferramentas de análise;
    - bug bounty;
    - pesquisadores;
    - profissionais de AppSec;
    - organizações que realizam testes de segurança.
  - Eles fornecem informações sobre vulnerabilidades encontradas em aplicações.

OWASP Top 10

- **Mas só os dados decidem?** Não.
  - A OWASP explica que o Top 10 é **data-informed**, mas não simplesmente **data-driven**.
  - Diferença → no **modelo data-driven** as decisões são tomadas de forma automatizada ou ditadas quase que exclusivamente pelos números. Já no **modelo data-informed**, os dados são apenas uma parte do processo, combinados com a intuição, o contexto humano e opiniões qualitativas.

OWASP Top 10

- **Abordagem Data-Driven (Orientado por Dados)**
  - Os números decidem o caminho de forma direta.
  - Foco total em métricas quantitativas e relatórios.
  - Reduz os "achismos", mas pode ignorar contextos subjetivos ou mudanças repentinas que os números passados não mostram.
  - Bom para cenários claros, previsíveis e processos repetitivos.
- **Abordagem Data-Informed (Informado por Dados)**
  - Os dados servem como conselheiros e guias, não como mandantes.
  - Mistura dados com experiência anterior, criatividade e conversas reais com pessoas.
  - Entende que um número isolado pode enganar se o contexto de fundo não for analisado.
  - Excelente para inovações, criatividade e cenários de muita incerteza.

OWASP Top 10

- **Porque a OWASP diz que o Top 10 é data-informed, mas não simplesmente data-driven?**
  - Imagine que surgiu uma vulnerabilidade nova ontem.
  - Ela pode ser extremamente perigosa, mas:
    - ninguém ainda teve tempo de criar ferramentas para detectá-la em milhões de sistemas.
  - Então os dados históricos podem dizer:
    - "Essa vulnerabilidade quase não aparece."
  - Mas os especialistas podem dizer:
    - "Calma aí. Isso acabou de surgir e tem potencial enorme."
  - Por isso existe também uma pesquisa com a comunidade de segurança e desenvolvimento.

OWASP Top 10

- **EXEMPLO**
  - Imaginem que eu queira descobrir quais são as doenças mais comuns em uma cidade. Eu poderia olhar: 🏥 prontuários; 💊 hospitais; 🧪 exames ; 📊 estatísticas
  - E descobrir: "Essas são as doenças que mais apareceram."
  - Mas aparece uma doença nova. Ela ainda tem poucos casos.
  - Se eu (que não sou especialista) olhar **somente para estatística**, posso ignorá-la.
  - O especialista olha e diz: **"Essa doença é extremamente perigosa e está começando a aparecer."**
- O OWASP faz algo parecido:
  - 📊 dados reais + 👨‍💻 experiência dos especialistas + 🗳️ opinião da comunidade = Ajudam a construir o Top 10.
- OWASP Top 10 não é uma lista de coisas que o programador deve decorar. É um mapa de onde procurar problemas de segurança

OWASP Top 10

- **A01:2025 - Controle de Acesso Quebrado**
  - O sistema permite que um usuário faça algo que não deveria ter permissão para fazer.
  - Autenticar responde quem você é. Controle de acesso responde o que você pode fazer.
- **A02:2025 - Configuração Insegura**
  - O sistema até pode ter uma boa segurança, mas foi configurado de maneira errada ou insegura.
  - Exemplo: DEBUG=true (em produção, mostrando erros e informações internas do sistema.)
  - Uma tecnologia segura também pode ficar insegura quando configurada errado.
- **A03:2025 - Falhas na Cadeia de Suprimentos de Software**
  - Seu sistema pode ser seguro, mas você utiliza bibliotecas, pacotes, frameworks, APIs ou componentes de terceiros que possuem vulnerabilidades.

OWASP Top 10

- **A04:2025 - Falhas Criptográficas**
  - Informações sensíveis não são protegidas corretamente através de criptografia, hashing ou mecanismos relacionados. Exemplo: Guardar senha = "123456" diretamente no banco.
  - Se alguém roubar o banco, encontra as senhas. Mesma coisa de guardar documentos importantes em caixa transparente.
  - O correto é utilizar mecanismos apropriados de armazenamento de senha, como hashing seguro.
- **A05:2025 - Injeção**
  - O sistema recebe uma entrada do usuário e acaba interpretando essa entrada como um comando ou código. Um exemplo clássico é SQL Injection. Jamais confiar na entrada de usuários.

OWASP Top 10

- **A06:2025 - Design Inseguro**
  - O problema está no projeto da aplicação, antes mesmo de pensarmos em um erro específico no código. Exemplo: Um sistema permite alterar a senha apenas informando CPF
  - Sem senha antiga, sem código, sem MFA e sem outra verificação.
  - Pode até não existir um "bug" no código. O problema é: O processo foi projetado de forma insegura.
- **A07:2025 - Falhas de Autenticação**
  - Problemas relacionados a login, senha, sessão, recuperação de senha, MFA etc.
  - Autenticação é provar que você realmente é quem diz ser.

OWASP Top 10

- **A08:2025 - Falhas de Integridade de Software ou de Dados**
  - O sistema confia em software, atualizações, arquivos ou dados que podem ter sido alterados indevidamente.
- **A09:2025 - Falhas de Registro e Monitoramento de Segurança**
  - O sistema não registra ou não monitora adequadamente eventos importantes de segurança.
  - Um atacante tenta entrar e o sistema não registra, não alerta ninguém e não bloqueia o comportamento suspeito.
  - Se você não registra e monitora, pode nem perceber que está sendo atacado.
- **A10:2025 - Tratamento Incorreto de Condições Excepcionais**
  - O sistema não trata corretamente erros, exceções, situações inesperadas ou condições anormais. Um sistema apresenta para o usuário:
  - ```
    SQLSTATE[HY000]:
    Access denied for user 'root'
    Database: producao
    Host: 192.168.1.50
    ```
  - O erro interno acabou revelando informações que poderiam ajudar um atacante.
  - Outro problema seria uma aplicação entrar em um estado inesperado e permitir uma operação que não deveria acontecer.
    ```

OWASP Top 10

OWASP	Pergunta que o desenvolvedor deve fazer
A01	👤 Quem pode fazer o quê?
A02	⚙️ Configurei tudo com segurança?
A03	📦 Posso confiar nas dependências?
A04	🔐 Protegi os dados corretamente?
A05	🚀 O usuário consegue injetar comandos?
A06	🏗️ O sistema foi projetado pensando em segurança?
A07	🔑 Tenho certeza de quem está acessando?
A08	🛰️ Posso confiar que meus dados/software não foram adulterados?
A09	📋 Eu saberia que estou sendo atacado?
A10	💥 O que acontece quando algo dá errado?

Onde aparecem em aplicações Node/React

ONDE O OWASP TOP 10 (2025) APARECE EM Node.JS + REACT

ARQUITETURA TÍPICA



OWASP TOP 10 (2025) EM CADA CAMADA

FRONTEND - REACT

A05:2025 – Injeção (XSS)
Inserir HTML/JS vindo do usuário de forma insegura.

```
dangerouslySetInnerHTML={{
  __html: comentario }}
/>
```

```
<div>{comentario}</div>
```

A07:2025 – Falhas de Autenticação
Armazenar tokens de forma insegura ou não tratar expiração/renovação.
Ex.: localStorage sem proteção.

A01:2025 – Controle de Acesso Quebrado
Esconder elementos de UI não é controle de acesso real.
A permissão deve ser validada no backend.

BACKEND - NODE.JS / EXPRESS

A07:2025 – Falhas de Autenticação
Login sem limites de tentativas, sessões mal gerenciadas, JWT sem expiração ou assinatura fraca.

A01:2025 – Controle de Acesso Quebrado
Não validar permissão do usuário para acessar recursos/rotas/dados de outros usuários.

A05:2025 – Injeção (SQL/NoSQL/Command)
Construir queries com concatenação de strings.

```
// ERRADO - SQL Injection
const sql = 'SELECT * FROM usuarios
WHERE email = '${email}'`
```

```
// CERTO - Query parametrizada
const sql = 'SELECT * FROM usuarios
WHERE email = ?'
```

A10:2025 – Tratamento Incorreto de Condições Excepcionais
Retornar erros detalhados demais para o usuário.
Ex.: stacks, queries, caminhos internos.

DADOS / INFRAESTRUTURA

A02:2025 – Configuração Insegura
Variáveis sensíveis no código, CORS aberto, modo debug em produção, portas e serviços desnecessários expostos.

A03:2025 – Falhas na Cadeia de Suprimentos de Software
Dependências com vulnerabilidades ou sem manutenção.
Ex.: pacotes NPM desatualizados.

A04:2025 – Falhas Criptográficas
Senhas sem hash forte, uso de algoritmos fracos, comunicação sem HTTPS.

A08:2025 – Falhas de Integridade de Software ou de Dados
Dados ou arquivos podem ser alterados sem verificação.
Ex.: não valcks, queries, caminhos internes. uploads sem validação.

A09:2025 – Falhas de Registro e Monitoramento de Segurança
Não registrar eventos críticos ou não monitorar comportamentos suspeitos.

REGRA DE OURO: Frontend controla experiência. Backend controla segurança.

EXEMPLOS PRÁTICOS

A05:2025 – INJEÇÃO (XSS)

React (Perigoso)

```
<div
dangerouslySetInnerHTML={{
  __html: comentario
}}
/>
```

React (Seguro)

```
<div>{comentario}</div>
```

A05:2025 – INJEÇÃO (SQL)

Node.js (Perigoso)

```
const sql = `SELECT * FROM usuarios
  WHERE email = '${email}'`
```

Node.js (Seguro)

```
const sql = 'SELECT * FROM usuarios
  WHERE email = ?'
db.query(sql, [email])
```

A01:2025 – CONTROLE DE ACESSO QUEBRADO

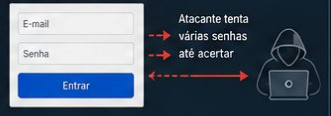
Usuário comum acessa:

```
GET /api/admin/usuarios
```

Backend NÃO valida permissão corretamente

A07:2025 – FALHAS DE AUTENTICAÇÃO

Login sem limite de tentativas



A03:2025 – CADEIA DE SUPRIMENTOS

Seu projeto



Um pacote vulnerável compromete tudo

A02:2025 – CONFIGURAÇÃO INSEGURA

.env (exemplo errado)

```
DB_USER=root
DB_PASSWORD=123456
JWT_SECRET=segredo123
```

Arquivo exposto ou enviado ao repositório

A09:2025 – REGISTRO E MONITORAMENTO

Tentativas de login

```
10:15:01  Falha
10:15:03  Falha
10:15:05  Falha
10:15:07  Falha
10:15:09  Falha
...
```

Sem logs e alertas nenhuma ação é tomada

A10:2025 – TRATAMENTO INCORRETO DE CONDIÇÕES EXCEPCIONAIS

Erro retornado ao usuário

```
Error: ER_ACCESS_DENIED_ERROR
at /src/db.js:25:13
SQL: SELECT * FROM usuarios
DB: producao
User: root
```

Informações internas expostas para o atacante

APLIQUE O OWASP TOP 10 EM CADA LINHA DE CÓDIGO, CONFIGURAÇÃO E DECISÃO.

SENAI

Atividade

Prática

Clone o github https://github.com/anabeatrizdsmorais/desi_2025-1 no seu computador, entre na pasta aula_19-08 e realize as seguintes atividades:

1. Analise o código e identifique pelo menos 6 vulnerabilidades de segurança. Objetivo: Identificar vulnerabilidades no código e relacioná-las ao OWASP Top 10 2025.
2. Você foi contratado para corrigir a API. Corrija pelo menos 5 vulnerabilidades identificadas no código, mantendo as funcionalidades existentes. Objetivo: corrigir as vulnerabilidades encontradas.

SENAI

Serviço Nacional de Aprendizagem Industrial

PELO FUTURO DO TRABALHO

0800 048 1212 **sc.senai.br**

Rodovia Admar Gonzaga, 2765 - Itacorubi - 88034-001 - Florianópolis, SC